INSTITUTO TECNOLÓGICO
DE BUENOS AIRES

INTERPRETACIÓN SEMÁNTICA DE SOLICITUDES WEB EN CAPA DE APLICACIÓN

ALUMNO/A: Cozzi, Alejandro (Leg. N° 294227)

DIRECTOR/A DE TESIS: Sarraute, Carlos

TALLER: Taller de Tesis 1 – Maestría en Ciencia de Datos

PROFESORES/AS: Salgado, Ariel | Sarraute, Carlos

BUENOS AIRES
PRIMER / SEGUNDO CUATRIMESTRE, 2026

Índice

1. Introducción **2**
1.1. Contexto del proyecto 2
1.2. Justificación del estudio 3
1.3. Alcances del trabajo 4

2. Estado de la cuestión **4**
2.1. Micromovilidad y sistemas de transporte compartidos 4
2.2. Teoría de Redes Complejas 6

3. Definición del problema **6**
3.1. Problema general 6
3.2. Preguntas de investigación 7

4. Descripción del set de datos **7**
4.1. Origen y contexto del dataset 7
4.2. Descripción técnica 7

5. Hipótesis **8**

6. Objetivos **8**
6.1. Objetivo General 8
6.2. Objetivos Específicos 8

7. Solución propuesta a desarrollar en el TFI o tesis **8**
7.1. Metodología 8
7.2. Técnicas / Herramientas 8

8. Cronograma de actividades **9**

9. Limitaciones **9**

1. Introducción

1.1. Contexto del proyecto

Contextualizar el escenario general, dominio temático y entorno donde se inserta el proyecto de investigación o desarrollo.

En el cine de acción, es habitual ver personajes asociados al ciberdelito, utilizados para resolver situaciones que demanda la trama. Eso en parte se debe a que en las últimas décadas, muchos de los activos más valiosos del planeta son digitales, como lo podría ser un tren o un banco a mediados del siglo pasado. Pero esa imagen que ha construido el cine, de un personaje aislado escribiendo cosas a gran velocidad y penetrando sistemas, tiene poca relación con la realidad, que habitualmente suele ser menos atractiva y mucho más cercana.

Un ejemplo real son los ataques de ingeniería social, orientados a tomar el control del *Whatsapp* de la víctima, o incluso de su Home Banking, ambos son parte del mismo problema, así como el correo del príncipe Nigeriano[1] que nos contacta para sacar fortunas de su país, el ícono del Messenger que se tiene que poner azul si reenviamos un mensaje a todos nuestros contactos (bajo amenaza de la eliminación de la cuenta) o los millones de mensajes que llegan a diario con felicitaciones por haber ganado un premio.

Del otro lado, los proveedores de servicios intentan concientizar a los usuarios, alertando sobre estafas, reenviando a la carpeta de Spam de los correos sospechosos o bloqueando la clave cuando alguien se equivoca varias veces, por tratarse de un posible ataque de fuerza bruta. La seguridad se asume como responsabilidad compartida y se distribuye en todos los niveles posibles, desde el desarrollo seguro de aplicaciones, filtros en la red perimetral, doble factor de autenticación, etc.

En uno de esos niveles se encuentra el cortafuegos de aplicación o WAF (Web Application Firewall), una tecnología desarrollada en la década de 1990 (vinculada al nacimiento de la WWW en 1993) especializada en analizar el tráfico web que llega a una aplicación y tomar acciones sobre esas solicitudes, en definitiva bloquearlas o dejarlas pasar.

Los WAF tradicionalmente aplican fórmulas de expresiones regulares (de ahora en más regex), basadas en firmas de ataques conocidos, sobre los requerimientos del cliente, aunque en los últimos años han sumado técnicas más variadas como listas de reputación de ips, bloqueos por geolocalización o detección de bots en base al comportamiento. Este trabajo apunta centralmente a la mejora de ese filtro basado en firmas de ataques conocidos.

Los CVE (Por *Common Vulnerabilities and Exposures*) son esos **ataques conocidos** mencionados, cada uno de ellos tiene un código de registro utilizado para realizar su seguimiento, el software afectado, formas de mitigación y relación con otros CVEs. A su vez, añade una capa de trazabilidad por lo que cada CVE queda ligado a la publicación de los parches y nuevas reglas de WAF cada vez que surge uno nuevo. En el mismo nombre, radica su debilidad: se trata de reglas y parches relacionados con vulnerabilidades conocidas, asumiendo de facto que antes de su publicación eran desconocidas.

[1] https://www.avast.com/c-nigerian-prince-scam

1.2. Justificación del estudio

Se debe explicitar la relevancia y conveniencia del estudio planteado, justificando el valor teórico, práctico o metodológico del trabajo.

Imaginemos un escenario donde un ciberdelincuente logra una forma de penetrar un sistema a partir de una vulnerabilidad del mismo (desconocida hasta el momento). En un lapso de tiempo (que podría durar entre un segundo y diez años) el responsable lo detecta y lo reporta. En ciberseguridad, ese momento se llama ***zero-day***, aun cuando la vulnerabilidad pueda haber existido desde tiempo atrás, se trata del día cero para el camino de soluciones posibles a ese problema.

El reporte de esa vulnerabilidad nueva, sería resuelto por una comunidad de colaboradores o por equipos de desarrollo, luego sería liberado el parche y posiblemente una regla de WAF asociada a esa vulnerabilidad. Después, los responsables de otros servicios con el mismo software en todo el mundo, aplicarían la actualización y el sistema volvería a ser seguro.

En un mundo ideal, ese proceso completo duraría un par de semanas, en el mundo real de 2025 ese proceso duró una media de 241 días, según el reporte de Cost of Breach que IBM publica cada año[**?**]. Si bien como demuestra el informe, ese proceso ha mejorado en los últimos años (en parte gracias a los paradigmas de desarrollo ágil y filosofías de CICD) es probable que nunca sea suficiente para cerrar esa ventana temporal de exposición, siguiendo ese pipeline de detección-reporte-actualización.

Este trabajo busca explorar posibles soluciones o reducciones de ese gap, a partir de técnicas y algoritmos de aprendizaje automático, aplicadas en la capa de WAF para detectar solicitudes maliciosas.

Un ejemplo no imaginario fue el caso de un CVE conocido como «Log4Shell» de 2021 reportado por un empleado de *Ali Baba Cloud* el 24 de noviembre y asumido por *Apache Software Foundation* el 10 de diciembre de ese mismo año. *Akamai*, un productor privado de WAF, publicó parches al día siguiente [**?**] y el Instituto Nacional de Estándares y Tecnología (de EEUU, NIST por sus siglas en inglés) en [**?**] el 12 de diciembre del mismo año. Como se señala en [**?**] la vulnerabilidad existía al menos desde 2016, cuando se publicó el trabajo de [**?**] y cuya existencia podría remontarse hasta 2013, año en que se publicó el *commit* que dio origen a la vulnerabilidad [**?**]. Los primeros parches no fueron suficientes, lo que requirió nuevas versiones publicadas sobre el mismo, hasta el 28 de diciembre de 2021 [**?**].

La vulnerabilidad tuvo notoriedad mundial ya que afectó a plataformas populares como Minecraft, Twitter y Cisco, y su difusión permitió miles de ataques efectivos en los primeros días y cientos de millones de dispositivos afectados [**?**]. Es difícil establecer una ventana temporal de exposición global para «Log4Shell», pero podríamos decir que como mínimo fue de alrededor de un mes, y como máximo, de 5 años.

Las técnicas aplicadas en «Log4Shell» no diferían demasiado de los ataques conocidos previamente. Sobre este supuesto, tiene sentido la propuesta de pensar un sistema de aprendizaje automático que trabaje junto a las reglas de WAF pero de forma más flexible que las mismas, basados en el comportamiento continuo de las solicitudes.

1.3. Alcances del trabajo

Detallar los límites operacionales y temporales del proyecto (qué abarca concretamente la investigación).

Clasificar solicitudes web utilizando técnicas y algoritmos de aprendizaje automático, trabajando junto al WAF, de mínima podría mejorar los ratios de detección e incluso detectar reglas que no se han configurado o no se han actualizado correctamente. De máxima, podría detectar una vulnerabilidad de ***zero-day***, antes de la publicación por los organismos de seguimiento y parcheo. No obstante es necesario tener en consideración las limitaciones intrínsecas a la propia propuesta desde lo práctico y lo conceptual.

En principio, el set de datos utilizado, proviene de un entorno controlado [**?**], desplegado *ad hoc* para investigación y no de un entorno de producción real. Los logs de tráfico web contienen información sensible, valiosa y confidencial que otorga demasiada información sobre el negocio y el desarrollo, por lo cual es esperable que en general no se publiquen.

Por otro lado, como se explica en el punto 3.1, actualmente se reconocen cerca de 80 tipos de ataques y es poco probable que un dataset contenga a todos los tipos de ataques y en cantidades medianamente balanceadas. No está de más mencionarlo aunque parezca trivial: los tipos de ataques que no estén en el entrenamiento, tampoco estarán en la predicción.

Si el insumo de datos principal es un conjunto de datos etiquetados, el proyecto nace con una dependencia externa, que a su vez plantea otras dificultades: el WAF etiquetando produce falsos positivos, los cuales serían tomados como referencia, contaminando el entrenamiento del modelo. Si en su defecto quisiéramos realizar el etiquetado a partir de análisis forense humano, el tiempo y costo de la producción de datos se dispararía, imposibilitando procesos de reentrenamiento automatizado y aun así, sin garantizar la certeza de las etiquetas.

En cualquier caso la solución no se propone como un reemplazo al WAF y sus reglas, sino como un complemento adyacente al WAF que pueda ofrecer una solución híbrida para aumentar la seguridad. Quedaría pendiente de analisis la forma técnica en que esa solución podría integrarse de forma eficiente en un WAF para trabajar en conjunto, sin quitarle rendimiento al tráfico.

2. Estado de la cuestión

Se deben estructurar las subsecciones según temáticas relevantes. Aclarar antecedentes de dominio (investigaciones sobre el problema específico) y antecedentes metodológicos (herramientas, algoritmos o técnicas previas aplicadas al área). Utilizar citas bibliográficas mediante BibTeX.

2.1. Micromovilidad y sistemas de transporte compartidos

Mejorar los niveles de detección de ataques en WAF a partir de los datos, es un problema constante y recurrente dado que la cantidad y creatividad de los ataques se sostiene en el tiempo. Las dinámicas elementales desde el punto de vista técnico para quienes no estén familiarizados con el problema de la seguridad y la acción del WAF son trabajadas en [**?**] donde se realiza una exploración metodológica acerca de

la arquitectura necesaria para detectar y bloquear amenazas de tipo SQLI; si bien menciona los aportes que podrían hacer las técnicas de deep learning en esa capa, no incluye ninguna en su propuesta. Sí aporta algunas nociones metodológicas que podrían ayudar en la etapa de experimentación y, sobre todo, al momento de comparar con los filtros heurísticos.

En cambio, [**?**] realiza una aproximación muy similar a la que pretende plantear este trabajo, aunque sobre presupuestos metodológicos diferentes. Si bien parte de arquitecturas transformers para la comprensión semántica de cada solicitud web, apunta al fine-tuning a partir de RoBERTa, antes que a la extracción de embeddings crudos para su posterior procesamiento. No buscan generalizar sobre un conjunto de solicitudes maliciosas per se, sino que proponen realizar un entrenamiento de modelos singulares para cada aplicación web.

Es probable que el entrenamiento singular tenga mucho sentido a la hora de detectar anomalías, aunque no queda del todo claro en ese trabajo cómo se realizaría el etiquetado ya que en los experimentos se utilizan datasets ya etiquetados como CSIC 2010 y DRUPAL.

En una segunda etapa, luego del fine-tuning de RoBERTa, utilizan OneClassSVM un clasificador binario para detectar los ataques en los datasets, y lo comparan con los aciertos(Ratio de aciertos o True Positive Rate, de ahora en más TPR) y falsos positivos (en adelante FPR por False Positive Ratio) usando ModSec como WAF.

La potencia de RoBERTa también fue utilizada en [**?**] donde los autores experimentaron con un ensamble bastante más complejo pero con algunos parámetros similares. Su trabajo también utiliza herramientas transformers, RoBERTa en particular y el dataset de CSIC 2010 para pruebas, además del dataset ATRDF 2023. Su propuesta se inspira en el framework GAN de forma muy original: identifican tokens reservados en el dataset original y los enmascaran con un token de máscara (literalment <MASK>), luego utilizan RoBERTa para generar el reemplazo esperable de esa fracción del código, lo cual entrega un dataset paralelo, distinto del original. A continuación utilizan nuevamente RoBERTa para comparar ambos, y calculan la similaridad del coseno de cada palabra para determinar anomalías. Por último, entrenan un clasificador de Random Forest para predecir y discriminar entre «tráfico normal» y «posible ataque».

Otra característica en común de los dos trabajos mencionados anteriormente es que ambos obtienen como resultado esa clasificación binaria.

En cambio en [**?**] los autores apuntan a entregar ambos tipos de clasificación, una binaria (que discrimine ataque / legítimo) y una multiclase, clasificando hasta 8 clases en total (incluyendo al tráfico legítimo). Partiendo de la extracción de embeddings de la solicitud http, proceden a añadirle ruido usando el algoritmo Da-Sana. Para construir los embeddings utilizaron Keras con un padding posterior para normalizar los largos (es decir recortando las líneas que exceden el largo determinado y completando con ceros las que no llegan a él) usando los datasets CSIC-2010 y ECML/PKDD.

Un desarrollo más amplio y complejo se encuentra en [**?**]. En este trabajo se presenta un proceso que acuña su propio nombre: DeepPTSD una sigla que describe básicamente el proceso propuesto, de Deep Learning Payload Traffic Detection Method Transfer Semi-Supervised Detection. Se trata de un ensamble bastante sofisticado que se entrena con datasets clasificados públicos y aspira a detectar líneas maliciosas en un WAF. A grandes rasgos el ensamble sigue un proceso similar a los demás, aunque con variantes en cada paso, por ejemplo los embeddings se extraen con Word2Vec luego se pre-entrena un modelo con esa información usando redes convolucionales.

Con los resultados se realiza una aumentación de los datos que sigue dos caminos: «keyword mining» que parte de un dataset de payloads y aplica una ecuación tf-idf para crear una biblioteca de payloads y luego una «payload perturbation» que reemplaza ciertos tokens que detecta similares a los de la biblioteca en la línea a analizar.

Los trabajos mencionados parecen coincidir en un problema central: las reglas de WAF son eficientes para detectar un alto porcentaje de solicitudes maliciosas, pero son incapaces de detectar algunos tipos de ofuscación. Además, por su propia naturaleza, surgen como reacción a la detección de vulnerabilidades de tipo ***zero-day*** y esa reacción abre una ventana de oportunidad para el ciberdelito.

Es por eso que se busca en todos una solución al problema a partir de los datos, con distintas estrategias que en definitiva resultan en una acción inmediata sobre una solicitud web, en la capa de WAF. Esta solución no implica un reemplazo del sistema de reglas tradicional, sino un complemento que mejore las métricas de detección. En cualquier caso, eso significa básicamente aumentar el TPR y reducir el FPR con distintas estrategias específicas de la ciencia de datos, en un margen de tiempo poco considerable.

Ninguno de los trabajos mencionados probó el rendimiento comparado de distintos modelos transformers, ni su combinación con distintos algoritmos de clasificación. Pero más allá de del aporte cuantitativo que podría aportar el testeo de combinaciones, no se está teniendo en cuenta el gran peso que podría tener un conjunto de variables obtenidas a partir de ingeniería de características, sobre los rendimientos en un modelo predictivo dentro de un WAF.

2.2. Teoría de Redes Complejas

En el ámbito metodológico, la teoría de redes complejas ha sido ampliamente utilizada para modelar grafos dirigidos y ponderados de transporte [2], evaluando propiedades topológicas e identificando nodos críticos de conectividad multimodal [3].

3. Definición del problema

3.1. Problema general

Describir en detalle la problemática concreta a abordar, sus causas y efectos.

La seguridad de los activos digitales es un problema a nivel global que dista de poder resolverse de forma taxativa. Hay muchos enfoques al respecto, en este trabajo se toma como referencia el modelo OSI [**?**] definido por la organización internacional ISO para la seguridad en las comunicaciones computacionales. Más allá del problema de seguridad global, este trabajo se focalizará en tres problemas dependientes de este, los cuales se intentarán explicar a continuación.

El modelo OSI define 7 capas abstractas de seguridad, una de las cuales, la capa 3 se ocupa de la seguridad de red. Es en esa capa donde se colocan los cortafuegos de aplicación, un filtro lógico que media entre una aplicación e internet y se ocupa, entre otras funciones, de definir si una solicitud es legítima o no para proceder a su bloqueo o redireccionamiento hacia el servicio.

Esa definición no es sencilla por varios motivos y la definición que se toma no siempre es la correcta. La OWASP Foundation (por sus siglas en inglés Open Web Application Security Project) reconoce 78 distintos tipos de ataques, aunque la cifra

está en constante movimiento. Cada uno de ellos no llega al WAF con una etiqueta de «malicioso» en el encabezado, sino que lo habitual es que se recurra a distintas técnicas de ofuscación para evitar la detección, lo cual constituye el primer problema.

Y esa detección, recurre principalmente a expresiones regulares que buscan patrones dentro de la solicitud que podrían ser signo de un ataque de los mencionados.

OWASP provee de forma abierta cerca de 300 reglas para ese fin a través del programa CRS (Owasp Core Rule Set) que se pueden implementar en cualquier WAF. Owasp desarrolló un WAF de código abierto, llamado ModSecurity (de ahora en más Modsec) al cual se le pueden definir esas reglas, con distintos niveles de paranoia. A mayores niveles de paranoia, más cantidad de falsos positivos, a menor, más posibilidades de bypass[2], lo cual constituye el segundo problema.

El tercer problema es procedimental: Supongamos que un atacante descubre una vulnerabilidad en un sistema (zero-day), los responsables de ese servicio vulnerado detectan la intrusión, lo reportan, Owasp u otro organismo produce una regla para ese exploit, publican la regla y se reconfigura el WAF con la actualización. Este pipeline produce necesariamente una ventana de oportunidad muy importante como se mencionó en el punto 1.2.

3.2. Preguntas de investigación

Formular las preguntas específicas que orientarán la investigación.

¿Cuáles son las estaciones que actúan como conectores críticos (alta intermediación) en la red EcoBici y cómo se agrupan espacialmente las estaciones formando comunidades de alto tráfico?

4. Descripción del set de datos

4.1. Origen y contexto del dataset

Contextualizar explícitamente de dónde proviene el dataset y cómo fue colectado.

Los datos provienen del portal de datos abiertos del Gobierno de la Ciudad de Buenos Aires (BA Data), conteniendo registros anonimizados recolectados automáticamente por los sensores de cada estación de EcoBici.

4.2. Descripción técnica

Explicitar las características de las variables e información relevante para el planteamiento de la hipótesis. Esta sección puede incluir gráficas, diagramas u otros recursos descriptivos según corresponda.

El dataset incluye variables estructuradas como ID de estación de origen/destino, fecha/hora inicio y fin, duración y coordenadas. A partir de estas variables se definen operacionalmente los nodos y aristas ponderadas de la matriz de adyacencia.

[2]La misma expresión que se utiliza en medicina, en seguridad se refiere a saltear una regla o un filtro.

5. Hipótesis

Formular la hipótesis de trabajo. Las variables operativas identificadas para la hipótesis deben haberse detallado previamente en la sección 4.

La red de viajes de EcoBici exhibe propiedades de tipo "mundo pequeño" una estructura comunitaria altamente modular, donde un subconjunto inferior al 15 % de las estaciones concentra más del 40 % del flujo total de intermediación del sistema.

6. Objetivos

6.1. Objetivo General

El objetivo general debe ser único en la mayoría de los casos.

Modelar y evaluar la topología de la red de trayectos de EcoBici para identificar nodos críticos y patrones de conectividad en la movilidad urbana de Buenos Aires.

6.2. Objetivos Específicos

Los objetivos específicos deben presentarse como títulos en negrita acompañados de descripciones cortas en un formato de lista de ítems numerada.

1. ***Construcción del grafo de movilidad:*** *Limpiar y transformar los registros de viajes en un grafo dirigido e interconectado de estaciones.*
2. ***Cálculo de métricas de centralidad:*** *Evaluar indicadores de grado, intermediación (betweenness) y cercanía para priorizar nodos estratégicos.*
3. ***Detección de comunidades:*** *Aplicar algoritmos de agrupamiento de grafos para identificar zonas urbanas con alta cohesión de viajes.*

7. Solución propuesta a desarrollar en el TFI o tesis

7.1. Metodología

Detallar el enfoque metodológico, fases de trabajo y procedimientos de análisis. Las actividades detalladas deben estar en correlato con los objetivos específicos y el cronograma de trabajo propuesto.

Se implementará un enfoque cuantitativo basado en la teoría de redes complejas. Se procesarán las matrices de origen-destino y se aplicarán algoritmos de análisis topológico.

7.2. Técnicas / Herramientas

Especificar lenguajes, librerías, marcos de trabajo o algoritmos a emplear.

Se utilizará Python con las librerías `NetworkX` e `igraph` para el modelado de grafos, `Pandas` para manipulación de datos y `GeoPandas` junto a `Folium` para visualización espacial.

8. Cronograma de actividades

Presentar una planificación estimada del proyecto mediante una tabla de 4 columnas (Semana, Fechas, Tareas, Entregable). Para las semanas iniciales colocar *En proceso* en los entregables y un entregable concreto al finalizar cada etapa.

Semana	Fechas	Tareas	Entregable
1–3	Desde 31/08/2026 hasta 18/09/2026	Extracción, ingesta y familiarización con el dataset	En proceso
4–6	Desde 21/09/2026 hasta 09/10/2026	Revisión de literatura sobre redes en transporte	Marco teórico
7–15	Desde ... hasta ...	Construcción de matriz de adyacencia y grafo	Código de modelado
16–25	Desde ... hasta ...	Cálculo de métricas de centralidad y comunidades	Reporte de métricas
26–35	Desde ... hasta ...	Validación de hipótesis y visualización espacial	Mapas de red
36–40	Desde ... hasta ...	Redacción de la memoria y preparación de tesis	Tesis finalizada

9. Limitaciones

Detallar las restricciones conceptuales, técnicas, geográficas o temporales del trabajo.

El análisis se encuentra limitado a los puntos de origen y destino sin disponer de la ruta GPS exacta tomada por el ciclista, además de verse afectado por variaciones estacionales climáticas y días festivos.

Referencias

[1] Lucía González, Martín y Pérez. Análisis espacio-temporal del sistema de bicicletas públicas ecobici. *Revista de Transporte y Movilidad Urbana*, 14(2):45–58, 2022.

[2] Mark Newman. *Networks: An Introduction*. Oxford University Press, Oxford, 2018.

[3] Ana Rodríguez, Carlos y Silva. Complex network topology in public transit systems. In *Proceedings of the International Conference on Urban Data Science*, pages 112–120, 2021.